Cybersecurity Threat Intelligence Report

Daily Threat Monitoring | Analysis Period: April 2026

Executive Summary

The current threat landscape demonstrates **heightened operational sophistication** among ransomware operators, with a notable shift toward **proprietary tooling**, **cross-platform capabilities**, and **wiper-like destructive behavior**. Intelligence analysis reveals **61 active ransomware groups** conducting high-volume campaigns, with emerging actors rapidly scaling operations alongside established operators maintaining persistence despite law enforcement pressure.

Critical Findings Summary

Category	Finding	Severity
Ransomware	Trigona deploying custom exfiltration tooling with kernel-level defense evasion	CRITICAL
Ransomware	VECT 2.0 operating as de facto wiper due to cryptographic flaws - recovery impossible	CRITICAL
Ransomware	NBLOCK actively targeting Windows environments with AES-256 encryption	HIGH
Vulnerability	CVE-2026-41940 (cPanel) - Authentication bypass actively exploited in the wild	CRITICAL
Vulnerability	CVE-2026-32202 (Windows Shell) - Zero-click spoofing exploited by APT28	CRITICAL
Campaign Activity	799 confirmed attacks in 30-day window; Qilin/Agenda leading with 107 victims	HIGH

Threat Actor Momentum Analysis

Actor Category	Groups	Trend
Established Operators	The_Gentelman (68), DragonForce (67), Akira (54), LockBit (37)	Persistent despite LE pressure
Rapidly Expanding	CoinbaseCartel (62, +182%), Krybit (20), Lamashtu (17)	Aggressive scaling observed

Geographic Targeting

Rank	Country	Victim Share
1	United States	41.4%
2	United Kingdom	Significant
3	Germany	Significant
4	France	Significant

Top Threats

1. Trigona Ransomware

Attribute	Details
Threat Classification	Double-extortion ransomware
Operational Status	Active (resumed after Oct 2023 disruption)
First Observed	October 2022
Ransom Demand	Monero cryptocurrency
Confidence Level	HIGH - Multiple source corroboration

Technical Profile

Key Development: Deployment of custom exfiltration tool `uploader_client.exe` represents significant maturation in operational security, moving away from commodity tools (Rclone, MegaSync) to reduce detection signatures.

Core Capabilities:

- Parallel upload support (up to 5 concurrent streams per file)
- TCP connection rotation at 2GB threshold to evade network monitoring
- Selective exfiltration targeting high-value file types (invoices, PDFs)
- Authentication-key restricted access to stolen data
- Kernel-level security product disablement

Observed Toolset

Tool	Purpose	MITRE ATT&CK Technique
HRSword (Huorong)	Kernel driver service	T1547.001
PCHunter, Gmer, YDark, WKTools	Security product disablement	T1562.001
DumpGuard, StpProcessMonitorByovd	Defense evasion	T1562.001
PowerRun	Privilege escalation	T1068
AnyDesk	Remote access	T1219
Mimikatz, Nirsoft	Credential theft	T1003.001

Persistence Mechanisms

Kernel-Level Driver Installation:

- Driver Name: HRSword (Huorong Security Driver)
- Installation Method: Kernel driver service creation via `CreateService()` API
- Persistence Type: BOOT_START service configuration
- Registry Path: `HKLM\SYSTEM\CurrentControlSet\Services\HRSword`
- Privilege Level: SYSTEM (Ring 0 kernel access)

BYOVD (Bring Your Own Vulnerable Driver) Technique:

- Exploits legitimately signed but vulnerable kernel drivers
- Common targets: `DBUtil_2_3.sys`, `AsIO.sys`, `gdrv.sys`, `capcom.sys`
- Enables kernel-level operations without custom driver signing
- Terminates EDR/AV processes from kernel space (unprotected operation)

Command & Control Infrastructure

Attribute	Technical Specification
Tool	`uploader_client.exe` (proprietary)
Protocol	TCP-based custom protocol
Concurrent Streams	Up to 5 parallel connections per file
Rotation Threshold	2GB data transfer
Authentication	Key-based access control

Network Evasion Techniques:

1. Connection rotation at 2GB threshold to evade traffic analysis
2. Selective exfiltration reducing traffic volume
3. Authentication-key restriction ensuring ransom leverage

---

2. VECT 2.0 Ransomware/Wiper

Attribute	Details
Threat Classification	Ransomware-as-a-Service (RaaS) / Destructive wiper
Operational Status	Active (v2.0 released February 2026)
Platforms	Windows, Linux, ESXi (cross-platform codebase)
Encryption Method	ChaCha20-IETF (flawed - no authentication/integrity protection)
Confidence Level	HIGH - Technical analysis confirmed

Critical Finding

VECT 2.0 operates as a de facto wiper due to fundamental cryptographic implementation flaws. Files exceeding 128 KB have three of four decryption nonces discarded, making recovery **impossible regardless of ransom payment**.

Design & Implementation Gaps

Flaw	Impact
No MAC or integrity protection	Misidentified as ChaCha20-Poly1305 in public reports
Non-functional encryption modes	`--fast`, `--medium`, `--secure` modes do not work
Self-cancelling obfuscation routines	Reduces encryption effectiveness
Thread scheduler degradation	Affects encryption performance

Universal 128 KB destruction threshold	Files >128KB permanently destroyed

Cross-Platform Execution Framework

Platform	Binary Format	Execution Method
Windows	PE (Portable Executable)	Native API, PowerShell loaders
Linux	ELF	Shell script wrappers, cron jobs
ESXi	ELF (POSIX-compatible)	`vmkfstools` integration

Ecosystem Affiliations

Affiliate	Role
TeamPCP	Known for supply-chain attacks
BreachForums	Data leak platform partnership

---

3. NBLOCK Ransomware

Attribute	Details
Threat Classification	Encryptor ransomware
Encryption Algorithm	AES-256
File Marker	`.NBLock` extension
Ransom Note	`README_NBLOCK.txt`
Negotiation Channel	Tor-based portal
Confidence Level	MEDIUM-HIGH - Behavioral analysis ongoing

Technical Profile

- Targets Windows environments with local/network share access
- Deploys secondary payloads (password stealers)
- No publicly available decryptor
- Attacker-controlled decryption keys

MITRE ATT&CK Mapping

Tactic	Technique	Implementation
Execution	T1106 - Native API execution	Direct system calls
Persistence	T1547.001 - Registry Run Keys	Auto-run keys
Persistence	T1546.001 - Event Triggered Execution	File association changes
Privilege Escalation	T1055 - Process Injection	Memory manipulation
Command & Control	T1090 - Anonymized channels	Tor-based C2

Distribution Vectors

Vector	Priority
Phishing emails with malicious attachments	HIGH
Cracked software distribution	MEDIUM
Exploit-based delivery	HIGH

---

4. Ransomware Landscape Overview (April 2026)

Campaign Statistics (30-day window)

Metric	Value
Active Groups	61
Confirmed Attacks	799
Top Operator	Qilin/Agenda (107 victims)

Established Operators (Maintaining Momentum)

Group	Victim Count	Notes
The		

Prioritized SOC Action List

HIGH PRIORITY (Review within 24h)

- Investigate CVE: CVE-2026-41940 - | **Vulnerability** | CVE-2026-41940 (cPanel) - Authentication bypass actively exploited in the wild | CRITICAL |
- Investigate CVE: CVE-2026-32202 - | **Vulnerability** | CVE-2026-32202 (Windows Shell) - Zero-click spoofing exploited by APT28 | CRITICAL |
- Investigate THREAT: Key Development - Key Development:** Deployment of custom exfiltration tool `uploader_client.exe` represents significant maturation in operational security, moving away from commodity tools (Rclone, MegaSync) to reduce detection signatures
- Investigate THREAT: Core Capabilities - Core Capabilities:
- Investigate THREAT: Parallel upload support (up to 5 concurrent streams per file) - Parallel upload support (up to 5 concurrent streams per file)
- Investigate THREAT: TCP connection rotation at 2GB threshold to evade network monitoring - TCP connection rotation at 2GB threshold to evade network monitoring
- Investigate THREAT: Selective exfiltration targeting high-value file types (invoices, PDFs) - Selective exfiltration targeting high-value file types (invoices, PDFs)
- Investigate THREAT: Authentication-key restricted access to stolen data - Authentication-key restricted access to stolen data
- Investigate THREAT: Kernel-level security product disablement - Kernel-level security product disablement
- Investigate THREAT: Kernel-Level Driver Installation - Kernel-Level Driver Installation:
- Investigate THREAT: Driver Name - Driver Name: HRSword (Huorong Security Driver)
- Investigate THREAT: Installation Method - Installation Method: Kernel driver service creation via `CreateService()` API
- Investigate THREAT: Persistence Type - Persistence Type: BOOT_START service configuration

- Investigate THREAT: Registry Path - Registry Path: `HKLM\SYSTEM\CurrentControlSet\Services\HRSword`
- Investigate THREAT: Privilege Level - Privilege Level: SYSTEM (Ring 0 kernel access)
- Investigate THREAT: BYOVD (Bring Your Own Vulnerable Driver) Technique - BYOVD (Bring Your Own Vulnerable Driver) Technique:
- Investigate THREAT: Exploits legitimately signed but vulnerable kernel drivers - Exploits legitimately signed but vulnerable kernel drivers
- Investigate THREAT: Common targets - Common targets: `DBUtil_2_3.sys`, `AsIO.sys`, `gdrv.sys`, `capcom.sys`
- Investigate THREAT: Enables kernel-level operations without custom driver signing - Enables kernel-level operations without custom driver signing
- Investigate THREAT: Terminates EDR/AV processes from kernel space (unprotected operation) - Terminates EDR/AV processes from kernel space (unprotected operation)
- Investigate THREAT: Network Evasion Techniques - Network Evasion Techniques:
- Investigate THREAT: Connection rotation at 2GB threshold to evade traffic analysis - Connection rotation at 2GB threshold to evade traffic analysis
- Investigate THREAT: Selective exfiltration reducing traffic volume - Selective exfiltration reducing traffic volume
- Investigate THREAT: Authentication-key restriction ensuring ransom leverage - Authentication-key restriction ensuring ransom leverage
- Investigate THREAT: VECT 2.0 operates as a de facto wiper - VECT 2.0 operates as a de facto wiper** due to fundamental cryptographic implementation flaws. Files exceeding 128 KB have three of four decryption nonces discarded, making recovery **impossible regardless of ransom payment
- Investigate THREAT: Targets Windows environments with local/network share access - Targets Windows environments with local/network share access
- Investigate THREAT: Deploys secondary payloads (password stealers) - Deploys secondary payloads (password stealers)
- Investigate THREAT: No publicly available decryptor - No publicly available decryptor
- Investigate THREAT: Attacker-controlled decryption keys - Attacker-controlled decryption keys

Technical Appendix: Research Sources

Threat Intelligence Sources

- Title: Trigona ransomware attacks use custom exfiltration tool to steal data URL: https://www.bleepingcomputer.com/news/security/trigona-ransomware-attacks-use-custom-exfiltration-tool-to-steal-data/ Published: 2026-04-23T00:00:00.000Z Summary: Summary:

- The Trigona ransomware group has begun using a custom exfiltration tool, “uploader_client.exe,” to steal data more quickly and evading defense tools.

- The tool supports up to five parallel uploads per file, rotates TCP connections after 2GB to avoid monitoring, can selectively exfiltrate high-value file types (excluding large media), and requires an authentication key to restrict access to stolen data.

- In March attacks, the group appears to have avoided common tools like Rclone/MegaSync to reduce detection, signaling a shift to proprietary malware.

- The exfiltration tool has been used to steal high-value documents (invoices, PDFs) from network drives.

- Trigona was a double-extortion ransomware operation (launched Oct 2022) demanding Monero ransoms. Although disrupted by Ukrainian activists in Oct 2023, Symantec notes the threat actors reportedly resumed activity.

- Additional tools observed in campaigns include Huorong Network Security Suite's HRSword as a kernel driver service, and other utilities (PCHunter, Gmer, YDark, WKTools, DumpGuard, StpProcessMonitorByovd) to disable security products. PowerRun has been used to run tools with elevated privileges; AnyDesk provided remote access; Mimikatz and Nirsoft were used for credentials.

- Symantec provides IoCs to help detect and block these latest Trigona operations.

Why this matters for threats to watch:

- Emergence of a bespoke data-exfiltration tool indicates heightened focus on efficient, covert data theft during the post-compromise phase.
- Use of kernel-level tools and privilege elevation increases the risk of evading endpoint protections.
- Focus on high-value documents and selective exfiltration signals targeted data theft patterns that defenders should monitor (e.g., unusual parallel uploads, 2GB connection rotations, authentication-key restricted stolen data).

If you're evaluating defenses or incident response for malware/ransomware campaigns, prioritize:

- Monitoring for custom exfiltration utilities and unusual TCP/parallel upload behavior.

- Kernel-driver loading and security tool tampering activities.

- Credential theft utilities (Mimikatz/Nirsoft) and remote access tools (AnyDesk) in unexpected contexts.

- IoCs from Symantec's report to tighten detections and block indicators.

- Title: VECT: Ransomware by design, Wiper by accident - Check Point Research URL: https://research.checkpoint.com/2026/vect-ransomware-by-design-wiper-by-accident/ Published: 2026-04-28T13:03:01.000Z Summary: Check Point Research flags VECT 2.0 as a dangerous ransomware that behaves as a wiper. Key points relevant to latest cybersecurity threats:

- What it does: VECT 2.0 permanently destroys large files (not just encrypts). The damage threshold is effectively 128 KB, with three of four decryption nonces discarded per file above this size, making recovery impossible for victims.

- Cross-platform flaw: The same flawed encryption design (Windows, Linux, ESXi) indicates a single codebase shared across platforms, using libsodium with ChaCha20-IETF (no authentication or integrity protection) instead of ChaCha20-Poly1305 AEAD.

- Misleading indicators: Public reports often misidentify the cipher as ChaCha20-Poly1305; in reality there is no MAC or integrity protection, and certain advertised modes (--fast, --medium, --secure) are ignored.

- Design and implementation gaps: Numerous bugs and anti-analysis evasion features exist, including self-cancelling obfuscation and a thread scheduler that degrades encryption performance.

- RaaS and threat ecosystem: VECT operates as ransomware-as-a-service and has publicized partnerships with TeamPCP (notable for supply-chain attacks) and BreachForums, signaling a strategy to leverage compromised software supply chains to widen impact.

- Impact and targets: Enterprise assets including VM disks, databases, documents, and backups are at risk due to the universal 128 KB threshold, transforming VECT into a near-term wiper threat for meaningful data.

- Timeline: v2.0 released February 2026; initial activity surfaced December 2025 with notable public exposure in early 2026.

Why this matters for defense:

- Treat VECT as a wiper-first threat with encryption-like behavior lacking integrity checks. Prioritize immutable backups, segmentation, and rapid recovery plans.
- Monitor for indicators of compromise tied to VECT's campaign patterns, including unusual file truncation behavior and standardized thresholds around 128 KB.
- Be aware of supply-chain risk tied to TeamPCP and related attacks; ensure software bill of materials (SBOM) and integrity checks for third-party components.
- Validate defenses against ChaCha20-IETF usage without authentication; ensure EDR/NDR signals catch anomalous file-age and write patterns consistent with VECT's behavior.

If you want, I can extract concrete IOC patterns, detection rules, and recommended mitigations tailored to your environment.

- Title: Ransom-DB | Live Threat Command Center URL: https://www.ransom-db.com/blog/ransomware-threat-landscape-report-april-2026-4 Published: 2026-04-29T09:00:00.000Z Summary: Summary:

- The report tracks 61 active ransomware groups over the last 30 days, totaling 799 confirmed attacks, with Qilin (Agenda) leading at 107 victims.

- United States remains the primary target (about 41.4% of victim volume), followed by the UK, Germany, and France.

- Emerging and rapidly expanding actors to watch: CoinbaseCartel (62 victims this period, up from 22), Krybit (20 victims), Lamashtu (17), and Lapsus (14). These groups indicate a shift toward high-velocity campaigns and quick scale.

- Established groups maintaining momentum: The_Gentelman (68), DragonForce (67), Akira (54), and LockBit (37) continue to operate despite law enforcement pressure.

- Technical takeaways: Qilin uses a Rust-based locker enabling cross-platform efficiency; many campaigns rely on initial access techniques such as compromised VPNs and credential purchases from IABs.

- Bottom line for defenders: Expect persistent, high-volume activity with a mix of legacy operators and aggressive new affiliates. Prioritize US-facing assets, monitor for rapid spikes from emergent groups (CoinbaseCartel, Krybit, Lamashtu, Lapsus), and strengthen defenses around initial access vectors and data exfiltration capabilities.

- Title: Weekly Intelligence Report – 17 April 2026 | Blade Intel URL: https://bladeintel.com/exploits/weekly-intelligence-report-17-april-2026/ Published:

2026-04-16T16:21:01.000Z Summary: Summary:

- Focus: The latest ransomware threats and active campaigns, with specific emphasis on NBLOCK ransomware as observed by CYFIRMA in April 2026.

- NBLOCK at a glance:

  - Behavior: Encrypts local and network files (AES-256), appends .NBLock, drops README_NBLOCK.txt ransom note, may modify desktop wallpaper, and warns against deleting key.bin. Operates via Tor-based negotiation portal for attacker communications.
  - Impact: Encrypts data and may deploy secondary payloads (e.g., password-stealers); targets Windows environments with access to local/network shares; can affect multiple industries and geographies.
  - Tactics (per MITRE ATT&CK): Execution via Native API; Persistence via Registry changes and Event Triggered Execution (including changing default file associations); Privilege Escalation via Process Injection; ongoing, user-coordinated negotiation through anonymized channels.
  - Distribution: Phishing emails, malicious attachments, cracked software, and exploit-based delivery.
  - Note: No publicly available decryptor, and paying attackers does not guarantee recovery; attackers maintain decryption control.

- Takeaways for defenders:

  - Focus on phishing resilience, monitoring for registry and startup/autorun modifications, and defenses against process injection.
  - Segment networks and restrict write access to network shares; monitor for mass file encryption behavior and suspicious ransom notes.
  - Prepare incident response playbooks around NBLOCK-like behavior and ensure offline backups to mitigate encryption impact.

- Context: The report situates NBLOCK within broader ransomware trends across industries and regions, highlighting how threat actors combine encryption-based extortion with anonymized C2 channels and multi-stage delivery.

- Title: Ransomware | Latest Threats | Microsoft Security Blog URL: https://www.microsoft.com/en-us/security/blog/threat-intelligence/ransomware/ Published: Unknown Summary: Summary:

- Topic: Ransomware threat landscape, including how ransomware-as-a-service (RaaS) lowers barriers for attackers and enables high-impact campaigns.

- What's new: Latest threats, active campaigns, and evolving attacker techniques; guidance on detection, containment, and recovery.

- Practical takeaways:

  - Strengthen identity and access controls to reduce initial access vectors.
  - Leverage AI/ML insights and threat intelligence to identify patterns of ransomware activity.
  - Implement Zero Trust, robust endpoint detection and response (XDR/EDR), and coordinated incident response.
  - Prioritize defenses and responses across Microsoft Defender for Endpoint, Defender XDR, and related security products.

- What to do now:
  - Monitor for indicators of ransomware activity and suspect ransomware behavior (credential abuse, lateral movement, rapid file encryption).
  - Harden backups and ensure offline/immutable copies to enable recovery.
  - Align security operations with actionable threat insights to shorten containment and recovery times.

If you want, I can pull out the top recent campaigns and notable attacker TTPs (techniques, tactics, and procedures) mentioned in the page and suggest concrete defensive controls mapped to each.

Vulnerability Intelligence Sources

- Title: Known Exploited Vulnerabilities Catalog | CISA URL: https://www.cisa.gov/known-exploited-vulnerabilities-catalog Published: Unknown Summary: Here's a concise, user-focused summary tailored to your query "latest CVEs exploited vulnerabilities security advisories":

- What KEV is: The Known Exploited Vulnerabilities (KEV) catalog by CISA is an authoritative, continuously updated list of vulnerabilities that have been actively exploited in the wild. It is intended to help organizations prioritize vulnerability management and patching.

- What you'll find: The catalog aggregates CVEs with:
  - Description of the vulnerability (affected product and flaw)
  - Known to be used in ransomware campaigns (Yes/Unknown/No)
  - Recommended action per vendor guidance and executive orders (e.g., apply mitigations, follow BOD 22-01 for cloud services, or discontinue affected products if mitigations are unavailable)
  - Administrative details: date added and due date for remediation
  - Additional notes and context per entry

- Example entries (illustrative):
  - CVE-2026-31431 (Linux Kernel): Privilege escalation via incorrect resource transfer between spheres; unknown ransomware use; remediation per vendor instructions; added 2026-05-01; due 2026-05-15.
  - CVE-2026-41940 (WebPros cPanel & WHM/WP2): Authentication bypass in login flow; unknown ransomware use; remediation per vendor; added 2026-04-30; due 2026-05-03.
  - CVE-2026-32202 (Microsoft Windows Shell): Protection mechanism failure enabling spoofing over network; unknown ransomware use; remediation per vendor; added 2026-04-28; due 2026-05-12.
  - CVE-2024-1708 (ConnectWise ScreenConnect): Path traversal enabling remote code execution; unknown ransomware use; remediation per vendor; added 2026-04-28; due 2026-05-12.
  - CVE-2024-57726 / CVE-2024-57728 (SimpleHelp): Missing authorization and path traversal vulnerabilities; potential privilege escalation and arbitrary code execution; unknown ransomware use; remediation guidance; added 2026-04-24 and 2026-04-24 respectively; due 2026-05-08 and 2026-05-08.

- How you can use it:

    - Prioritize patches for actively exploited CVEs first, using the “Date Added” and “Due Date” as your remediation timeline.
    - Review “Known To Be Used in Ransomware Campaigns?” to gauge urgency.
    - Follow vendor-specific mitigation steps and broader guidance (e.g., BOD 22-01) for cloud and hybrid environments.

- Formats available: KEV catalog is accessible in multiple formats beyond the webpage for integration into vulnerability management tools.

If you want, I can:

- Pull the very latest top 5–10 entries currently marked as exploited or high-risk.

- Generate a quick-priority patching checklist based on the newest additions.

- Filter entries by product, CVE year, or

- Title: Newest CVEs | Tenable® URL: https://www.tenable.com/cve/newest Published: Unknown Summary: Here’s a concise summary focused on the user query “latest CVEs exploited vulnerabilities security advisories” from the Tenable Newest CVEs page:

- What it is: A live listing of the newest publicly disclosed CVEs across vendors, with brief descriptions, severity indicators, and update timestamps.

- Recent notable CVEs (examples):

    - CVE-2026-7687 (langflow-ai): Remote command injection in langflow up to 1.8.4 via CodeParser.parse_callable_details. Public exploit disclosed.
    - CVE-2026-7686 (Adblock Plus for Chrome): Remote access control flaw in Legacy Premium Activation via postMessage; exploit public. Vendor notes the old flow is deprecated and risk is low-to-moderate.
    - CVE-2026-7685 (Edimax BR-6208AC): Remote buffer overflow in /goform/setWAN when manipulating pptpDfGateway (up to 1.02). Public exploit.
    - CVE-2026-7684 (Edimax BR-6428nC): Remote buffer overflow in /goform/setWAN via pptpDfGateway; public exploit.
    - CVE-2026-7683 (Edimax BR-6428nC): Remote command injection via /goform/setWAN (pppUserName/pptpUserName); exploit publicly available.

- How to use this page:

    - Scan for CVEs by severity to prioritize patches (high/medium).
    - Note the vendor advisories and whether exploits are public to gauge urgency.
    - Check the linked CVE details for affected products, suggested mitigations, and upgrade paths.

- Takeaways:

    - The list highlights several critical/high-severity network device and software vulnerabilities with active exploitation or publicly disclosed exploits.
    - Prioritize affected systems (especially exposed devices like Edimax routers and web components) for patching or mitigations.

- Title: cPanel and WHM Authentication Bypass Vulnerability Exploited in the Wild (CVE-2026-41940) – Qualys ThreatPROTECT URL: https://threatprotect.qualys.com/2026/04/30/cpanel-and-whm-authentication-bypass-

vulnerability-exploited-in-the-wild-cve-2026-41940/ Published: 2026-04-30T00:00:00.000Z Summary: Summary tailored to "latest CVEs exploited vulnerabilities security advisories" intent:

- Critical CVE: CVE-2026-41940 affecting cPanel & WHM. Actively exploited in the wild.
- What it does: An attacker can bypass authentication to gain root control over the cPanel host, its configurations, databases, and managed websites. Exploitation chain includes CRLF injection, session manipulation, and cache promotion to bypass password checks.
- How it works (high level):
  1. Mint preauth session via failed login to generate a session cookie and raw session file.
  2. Use CRLF injection in a crafted Authorization header to modify the raw session data.
  3. Promote a manipulated cache by requesting a token-denied endpoint, causing the system to parse injected lines as valid keys.
  4. Bypass password checks on subsequent authenticated endpoints, granting root access without credentials.
- Affected versions (before patch):
  - cPanel & WHM: 11.110.0.x, 11.118.0.x, 11.126.0.x, 11.132.0.x, 11.134.0.x, 11.136.0.x
  - WP Squared 11.136.1.x
- Fixed in vendor patches:
  - cPanel & WHM patched releases: 11.86.0.41, 11.110.0.97, 11.118.0.63, 11.126.0.54, 11.130.0.19, 11.132.0.29, 11.136.0.5, 11.134.0.20
  - WP Squared patched: 136.1.7
- Mitigation steps (essential):
  - Immediately upgrade to patched versions:
    - Run: /scripts/upcp --force
  - Verify build version: /usr/local/cpanel/cpanel -V
  - Restart cpsrvd: /scripts/restartsrv_cpsrvd
  - Ensure you’re not on an unsupported/incorrect update channel
- Additional note:
  - If updates are disabled or update conf pinned, apply patches per vendor advisory and consult the linked Vendor Security Advisory for details.

Key takeaway: Apply patches urgently to mitigate a high-severity authentication bypass that could grant full server and site control.

- Title: CISA, Microsoft warn of active exploitation of Windows Shell vulnerability (CVE-2026-32202) - Help Net Security URL: https://www.helpnetsecurity.com/2026/04/29/windows-cve-2026-32202-exploited/ Published: 2026-04-29T10:20:42.000Z Summary: Summary tailored to: "latest CVEs

exploited vulnerabilities security advisories"

- CVE-2026-32202: A zero-click Windows Shell spoofing vulnerability actively exploited in the wild. It stems from an incomplete patch for CVE-2026-21510 (and related CVE-2026-21513) previously exploited by APT28 via weaponized LNK files.
- Exploitation details: Even without opening a malicious LNK, Windows Explorer rendering the folder can trigger an SMB connection that causes an NTLM authentication handshake. The victim's Net-NTLMv2 hash can be exposed, enabling NTLM relay attacks and offline cracking.
- Affected systems: Windows 10, Windows 11, and Windows Server versions still supported.
- Patch status: Microsoft released fixes on April 14, 2026 for the underlying flaws, but Microsoft did not flag CVE-2026-32202 as actively exploited at the time, delaying urgency signals. CISA and Microsoft later confirmed active exploitation.
- Mitigation recommendations:
  - Apply the April 14, 2026 patch immediately if not already installed.
  - Consider blocking outbound SMB traffic at the network perimeter to reduce exposure to NTLM relay attacks.
  - Monitor for indicators of exploitation and ensure security teams treat patched vulnerabilities with urgency when exploitation is possible, even if the exact CVE is not flagged as exploited initially.
- Context: This highlights a broader risk gap between patch release and true protection, and the importance of timely vulnerability signaling and network-level mitigations in preventing zero-day-like exploits.
- Title: cPanel's authentication bypass bug is being exploited in the wild, CISA warns | CyberScoop URL: https://cyberscoop.com/cpanel-authentication-bypass-vulnerability-cve-2026-41940-exploited/ Published: 2026-04-30T20:49:07.000Z Summary: Summary:
- A severe authentication bypass flaw in cPanel/WHM (CVE-2026-41940) is actively exploited in the wild.
- Affects all supported cPanel/WHM versions released after 11.40, plus WP Squared (WordPress hosting on cPanel).
- Exploitation method: attacker injects hidden line breaks in the login password field, causing server-side session data to be written with embedded data, which is later interpreted as authenticated, skipping actual credential checks.
- Rapid7 scans via Shodan found ~1.5 million exposed instances; exact vulnerable count unknown.
- Patches released by cPanel address seven version branches (11.110.0 to 11.136.0, across multiple releases). Exploitation began before fixes were available.
- KEV listing: CISA added the CVE to Known Exploited Vulnerabilities; Namecheap and other providers took protective action (temporarily blocking cPanel/WHM ports 2083/2087; applying patches as released).

- Detection and mitigation:
  - Use cPanel's detection script to scan for indicators of compromise (IOC): compromised session files, authentication timestamps, pre-authenticated sessions, and password fields with embedded newlines.
  - Consider tools like WatchTowr's Detection Artifact Generator to verify vulnerability status on instances.
  - Apply the latest cPanel/WHM WP2 security updates across all affected branches (11.110.0 through 11.136.0) and related WP Squared components.
  - Review network access to cPanel/WHM ports (2083/2087) and implement port-layer protections if patches aren't yet deployed.
- Practical takeaway: patch promptly, run IOC scans, and monitor for anomalous login/session behavior as exploitation has been observed in the wild.